

ASSESSMENT METADATA

Target http://localhost:3000
Environment SYNTHETIC LOCAL SECURITY LAB
Assessment Type Controlled Demonstration
Generated 2026-09-29
Status Completed

EXECUTIVE SUMMARY

TOTAL	CRITICAL	HIGH	MEDIUM	LOW
2	0	1	1	0

ASSESSMENT SCOPE

This report documents findings produced during a controlled synthetic security assessment of a local World Monitor test target.

FINDINGS OVERVIEW

ID	FINDING	SEVERITY	CWE	STATUS
WM-API-432	Unauthenticated API Access on Admin Endpoint	High	CWE-285	Confirmed
WM-WEB-105	Cross-Site Scripting (XSS) in Dashboard Search	Medium	CWE-79	Confirmed

WM-API-432

Unauthenticated API Access on Admin Endpoint

HIGH

Severity	High	CVSS	8.5	CWE	CWE-285
Category	Authentication	Component	/api/admin/users	Status	Confirmed

1. DESCRIPTION
- The /api/admin/users endpoint allows access without a valid authentication token. Any user can view PII of all registered users.
2. STEPS TO REPRODUCE
- 01 Send GET request to /api/admin/users

02 Observe JSON response containing user PII
3. PROOF OF CONCEPT / EVIDENCE
- [POC EXECUTION] Verified finding WM-API-432
Target: http://localhost:3000
Payload: ' OR 1=1--
Result: Bypass successful
4. BUSINESS IMPACT
- Compromise of user data, potential regulatory fines.
5. REMEDIATION
- Implement token validation middleware on all /api/admin routes.
6. DISCLOSURE STATUS
- Not recorded

WM-WEB-105

Cross-Site Scripting (XSS) in Dashboard Search

MEDIUM

Severity	Medium	CVSS	6.1	CWE	CWE-79
Category	Input Validation	Component	Dashboard Search Input	Status	Confirmed

1. DESCRIPTION
- The search parameter on the dashboard is reflected in the DOM without sanitization, allowing arbitrary script execution.
2. STEPS TO REPRODUCE
- 01 Enter <script>alert(1)</script> in search
3. PROOF OF CONCEPT / EVIDENCE
- [POC EXECUTION] Verified finding WM-WEB-105
Target: http://localhost:3000
Payload: ' OR 1=1--
Result: Bypass successful
4. BUSINESS IMPACT
- Session hijacking, unauthorized actions on behalf of the user.

AEGIS

World Monitor Security Assessment

5. REMEDIATION

Use context-aware output encoding or a safe UI framework like React without dangerouslySetInnerHTML.

6. DISCLOSURE STATUS

Not recorded